PipelineFortress

Secure CI/CD with GenAI-assisted triage. CAP-DSE-3W individual study implementation and evidence report.

Six security stages	Application tests	Underlying issues
Executed locally	2,326 passed / 7 skipped	235 open and deferred

Outcome and operating decision

The owned lab now executes SAST, dependency, secret, IaC, image and passive runtime scans. A hardened source-built image is linked through deployment, container inventory and scan evidence. Source-free normalization, mock triage, refusal tests and bounded local patch templates are implemented.

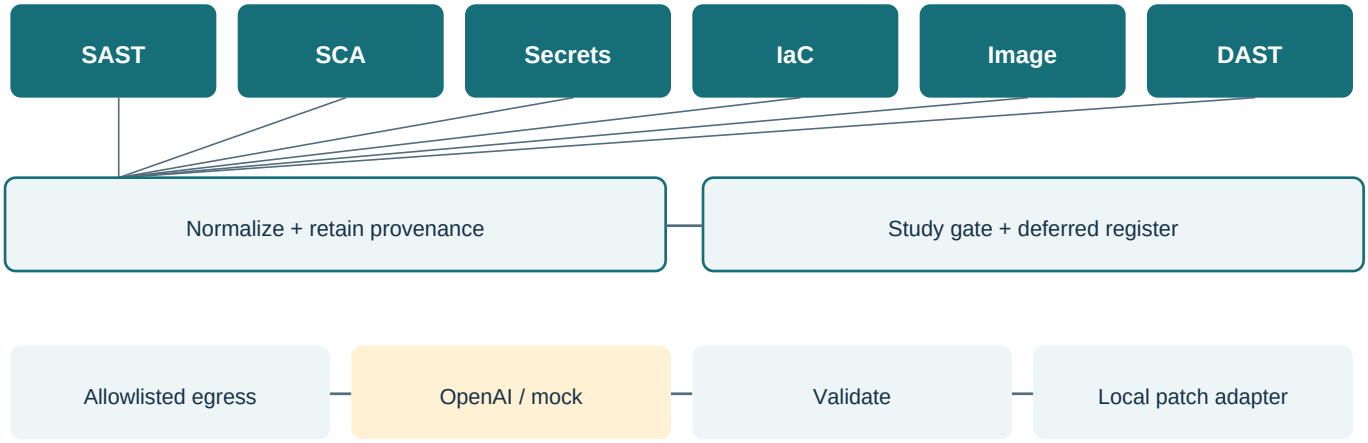
On 22 October the project owner directed completing the study assignment before later vulnerability remediation. The study profile therefore records security findings and continues. It does not convert findings into fixes or authorize production promotion.

Completion boundary

Local pipeline execution and the three example proposal regressions are verified. Successful live API triage remains unverified: the selected OpenAI credential passed model lookup but three bounded generation attempts returned HTTP429. Genuine human review is recorded only when received. Hosted and fresh-directory status are shown explicitly later in this report.

This report is an evidence snapshot, not an assertion that every assessment dependency has been fulfilled.

Architecture and trust boundaries



Every scanner retains raw reports in ignored local storage and publishes only execution receipts, aggregate counts, opaque finding fingerprints and checksums. Job receipts bind one run and commit; build, container and DAST receipts must agree on the image configuration ID.

Normalization creates observation IDs and underlying-issue IDs. Source/container dependency observations share an issue when advisory, component and version agree; detecting stages and every source record remain available. A matching title alone is not a deduplication key.

The AI boundary constructs a new allowlisted object. It sends synthetic IDs, verified rule/advisory references, severity/category, aliases and verified public versions. Private locations, source, matches, account details and raw scanner messages remain local. The model receives no shell, repository, file or write tools.

Validated operations map to fixed local templates. A human review step is separate from generation, scanner success and author self-review. No automatic merge is implemented.

Environment and application verification

Component	Verified configuration
Target	OWASP Juice Shop 20.3.0; immutable imported source; original license retained
Node / Python	Build Node 24.22.0; runtime 24.22.1; isolated Python 3.10
Scanners	Semgrep 1.181.0; Trivy 0.76.0; Gitleaks 8.30.1
IaC / inventory / runtime	Checkov 3.3.30; Syft 1.55.0; ZAP 2.17.0
Kubernetes lab	kind 0.33.0; Kubernetes/kubectl 1.37.0
Installation boundary	Project/user-local tools; scanner distributions and base images pinned

The fresh offline application profile passes root/frontend installation, explicit production build, frontend tests, server tests and local API tests. Counts are 1,372 frontend, 417 server and 537 API tests passed, with seven upstream skips and zero selected failures.

A separate online attempt retained six failures from external-service DNS lookup errors. The offline profile excludes the entire nine-test internet-resource availability suite. It does not suppress a local application test failure. Historical online baseline counts remain separate.

Application source and both retained dependency locks are preserved. Supported runtimes, lock comparisons and exact image identity are checked rather than inferred from a tag.

Observed runtime baseline

Observation	Hardened runtime result	Interpretation
Home / products / languages	HTTP200; data present	Application remains usable
Coding snippet	HTTP200	Training source snippets remain available locally
FTP directory	HTTP200	Intentional directory listing remains
Metrics	HTTP200	Unauthenticated metrics remain observable
Malformed product search	HTTP500 with SQL error shape	Training error disclosure remains

Seven functional/training checks pass in Docker and Kubernetes. The observations are against the owned lab only. No external exploitation, authenticated coverage or customer-data access is claimed.

Infrastructure hardening preserves the intentionally vulnerable application. Its behavior is part of the study baseline and remains in the deferred register. A passing runtime check establishes the expected behavior, not absence of security weaknesses.

The active hardened workload is Ready with zero restarts at verification. Earlier readiness issues in other pre-existing system pods are retained as a lab limitation; application readiness is not a complete cluster-health or CIS assessment.

Six stages and the authoritative verdict

Stage	Normalized observations	Execution
SAST	11	Complete; findings deferred
SCA	82	Complete; findings deferred
SECRETS	136	Complete; findings deferred
IAC	1	Complete; findings deferred
CONTAINER	100	Complete; findings deferred
DAST	42	Complete; findings deferred

The complete local run is 20261022T145253045022Z. Its aggregate verdict is PASS_WITH_DEFERRED_RISKS, with 0 operational errors. The stage receipts retain raw report hashes and exact image linkage.

That execution took 115.75 seconds after explicit reuse of a freshly verified build/test. The application check stages took 144.17 seconds separately; these observations do not establish a pipeline percentile or include every bootstrap/download cost.

The hosted workflow defines six scan jobs, build/test and one final aggregate job. It uses read-only PR permissions, pinned action SHAs, full history for secrets, an integrity-checked image archive between jobs and cleanup of its own staging cluster. Skipped jobs, malformed/missing receipts, scanner errors and mixed identities cannot pass the execution check.

Hardening and software inventory

Measure	Baseline	Hardened
Failed Kubernetes checks	15	1
Failed Dockerfile checks	2	0
Image vulnerability identities	101	100
Critical / high / unknown	11 / 27 / 1	11 / 27 / 0
Image bytes	351,789,266	345,391,667
CycloneDX components	Not claimed here	2748

The runtime uses UID/GID 65532, no effective or bounding capabilities, no-new-privileges, RuntimeDefault seccomp and a read-only root filesystem. Application code and immutable seed reject writes. Explicit bounded writable mounts preserve SQLite, restored training files, translations, customized frontend media, uploads, logs, CSAF metadata and temporary files.

Both immutable image configuration IDs were scanned under one frozen Trivy database. One unknown CA-certificate advisory was removed; no new identity was introduced in that comparison. The 38 high/critical image identities remain. Syft CycloneDX 1.6 validates against hash-pinned official schemas and representative installed package versions.

Selected controls are mapped to CIS Kubernetes 2.0.0. NetworkPolicy remains a declared gap and enforcement is unverified. No full benchmark or cluster certification is claimed. A Docker configuration ID, a registry base index digest and a local containerd manifest digest are different identifiers.

Passive DAST and coverage limits

Item	Observed result
Scanner	ZAP 2.17.0; official image pinned by digest
URLs recorded	121
Alert groups by risk code	{"2": 2, "1": 8, "0": 4}
Verified seed routes	Home, product search, languages, FTP and metrics
Rule policy	Selected header rules retain FAIL classification; study verdict defers findings
Isolation / cleanup	Owned node network namespace; loopback API; scanner container removed

The scan uses a traditional unauthenticated crawler and passive checks. It does not establish full single-page-app navigation, login/role coverage, active attack coverage, business-logic correctness or endpoint completeness. Passive alert-instance limits are retained as scanner coverage limits.

Early scanner-start attempts exposed loopback IPv6 and API Host-header allowlist mismatches. The corrections allow only the local API client and retain diagnostics. Successful scanning is supported by recorded app routes and report hashes, rather than a container exit code alone.

HTTP findings remain visible in normalization and the deferred register. The security result is not rewritten as clean merely because assignment execution continues.

Detection evaluation and dashboard

TP	FP	FN	TN	Labeled cases
14	0	1	6	21

Precision	Recall	F1	Known introduced / caught
100.0%	93.3%	96.6%	15 / 14

The curated set combines deliberately unsafe and repaired source, advisory, canary, configuration, image and response-header cases. It includes a real scanner miss: the six authored SAST pattern rules do not detect an unprotected synthetic export route. That fixture is never executed against a real service.

The measured 93.3% fixture recall exceeds the scenario target on this small set. Labels were curated after the broader study work and are not independently human reviewed. The result is not an estimate of all real-world vulnerabilities, a blinded benchmark or evidence that remaining app defects were found.

The dashboard recomputes from normalized evidence and labels, exports JSON/CSV, separates observations from underlying issues and displays known misses. Empty denominators are N/A. It does not present percentiles from one timing observation. Current global underlying issue count is 235.

AI safeguards and honest live status

Boundary	Implemented evidence
Input construction	Exact field allowlist; synthetic IDs and aliases; independent scanner-derived version catalog
Refusal behavior	Unknown fields, invalid schemas, unverified/encoded metadata and duplicate IDs refuse before transport
Actual HTTP body	Mock captures final serialized request; private paths/source/canaries excluded
Grounding	Unknown IDs, invented CVEs/versions, unsupported operations and omissions rejected
Live restrictions	OpenAI only; no tools; store=false; bounded tokens, attempts and conservative reservations

60 tests cover the relevant normalization, aggregate, boundary, grounding and bounded-patch behavior. A twenty-finding mock batch validates; mock output is deterministic policy behavior and is not reported as a real model evaluation.

The user-selected existing OpenAI key passed read-only model lookup. All three bounded generation attempts returned HTTP429; a specific underlying cause was not established. No successful model output or actual token/invoice cost is fabricated. The request cap is exhausted. No credits were purchased, account topped up or billing settings changed.

OpenAI documents standard abuse-monitoring retention separately from response storage. store=false does not establish zero retention or an account-specific ZDR setting. Only source-free metadata was submitted, and account-level retention settings were not independently verified.

Three focused remediation examples

Proposal	Control	Measured verification
pf-001	disable-sa-token	Checkov fails before / passes after; both deployments Ready; home/products pass; namespace cleaned
pf-002	require-nonroot	Checkov fails before / passes after; both deployments Ready; home/products pass; namespace cleaned
pf-003	add-liveness-probe	Checkov fails before / passes after; both deployments Ready; home/products pass; namespace cleaned

These examples modify only the legacy baseline deployment manifest through fixed local templates. They disable unnecessary service-account token mounting, explicitly require non-root execution and add a liveness probe. The original baseline image already runs non-root; the second proposal adds an explicit policy guarantee rather than claiming an observed root process was removed.

Each proposal has a bounded single-file diff, before/after hashes, actual selected-check evidence, functional observations and rollback instructions. Unsupported operations, path traversal, credential access, arbitrary commands and workflow edits are outside the adapter allowlist.

The Codex coding assistant authored the templates. The unavailable external application API is not credited with generating them. Three examples do not close the larger risk backlog, which remains deferred by the user.

Draft PR links recorded: 0. Genuine review/first-review correctness is pending unless the review ledger records a real verdict. No author self-approval, fabricated independent review or automatic merge is claimed.

Reproduction and maturity self-assessment

Reproduction bootstraps project-local Python/pip/Node and verified scanner/tool distributions, runs the selected application suites, rebuilds the image, scans all stages, deploys into a uniquely named temporary kind cluster, runs passive DAST, normalizes, checks mock AI safeguards and regenerates the dashboard. Live API usage is excluded from reproduction by default.

Fresh-directory result: not yet recorded. The script deletes only its own temporary cluster and retains sanitized execution evidence. The original study cluster is a separate resource.

OWASP SAMM v2 lens

Practice	Baseline	Current lab evidence / limit
Secure Build	Manual setup and selected tests	Repeatable pinned build, dependency inventory and automation; mature production prevention not claimed
Security Testing	Runtime observations	Six scanner stages and negative controls; known misses and limited DAST coverage retained
Defect Management	Findings not consolidated	Deduplicated register, labels and focused proposals; real human reviews still required
Strategy and Metrics	Planning estimates	Recomputable counts, fixture precision/recall and execution timings; one lab/run is limited evidence

SAMM uses maturity activities across three levels and fifteen practices. Selected level-one and automation activities are evidenced here, but this short project does not complete a formal SAMM assessment or justify an overall organizational score. Deferred production defects and missing independent review prevent a mature-production assurance claim.

Ethics, residual risks and references

The target is the owned local training application and ephemeral CI/reproduction labs. The acknowledgement was confirmed before Day 4 implementation resumed. Signed material, API credentials, raw scanner matches, private paths and the complete SBOM remain outside public artifacts.

The current deferred register contains 235 underlying issues, including 11 critical and 109 high. Deferral is an explicit study decision, not remediation. Later work should prioritize compatible dependency fixes, tested traffic isolation, genuine-secret response if ever confirmed and human-reviewed behavior-preserving changes.

GenAI disclosure: the Codex coding assistant authored implementation, tests, documentation and bounded proposals. OpenAI GPT-6 Luna is the configured external triage model; unsuccessful live attempts and mock results are separated. Human review and remaining assessment dependencies are not invented.

Reference	Location
Project evidence	docs/evidence-index.md and docs/project-completion.md
ZAP baseline behavior	https://www.zaproxy.org/docs/docker/baseline-scan/
Kubernetes controls	https://kubernetes.io/docs/tasks/configure-pod-container/security-context/
CIS benchmark scope	https://www.cisecurity.org/benchmark/kubernetes
OWASP SAMM v2	https://owaspsamm.org/model/
OpenAI model / price	https://developers.openai.com/api/docs/models/gpt-6-luna
OpenAI data controls	https://developers.openai.com/api/docs/guides/your-data

Submission limits: successful external live triage, genuine PR review and any unrecorded hosted/fresh run must remain open requirements. No grade, exhaustive detection, full CIS compliance or production readiness is asserted.